



Bundesamt
für Sicherheit in der
Informationstechnik

Deutschland
Digital•Sicher•BSI•

Technische Richtlinie TR-03174: Sichere Anwendungen im Finanzwesen

Teil 1: Mobile Anwendungen
Version 4.0



Änderungshistorie

<i>Version</i>	<i>Datum</i>	<i>Name</i>	<i>Beschreibung</i>
1.0	01.04.2022	Referat DI24	Erste Version
2.0	23.02.2024	Referat D24	Anpassungen für Erweiterung auf TR-Familie Überarbeitung Kapitel 3.1.6 Überarbeitung Kapitel 4.3.6 Erstellung Anhang B
3.0	16.09.2024	Referat D24	Finalisierung
3.1	14.11.2024	Referat D24	Bereinigung kleiner Unstimmigkeiten
4.0	01.06.2026	Referat D24	Ganzheitliche Überarbeitung der TR, Inhalt und Struktur

Bundesamt für Sicherheit in der Informationstechnik Postfach 20 03 63
53133 Bonn

Tel.: +49 22899 9582-0

E-Mail: payment@bsi.bund.de

Internet: <https://www.bsi.bund.de>

© Bundesamt für Sicherheit in der Informationstechnik 2026

Inhalt

1	Einleitung.....	5
1.1	Gegenstand der Technischen Richtlinie.....	5
1.2	Übersicht der Technischen Richtlinie	5
1.2.1	Aufbau.....	5
1.2.2	Begriffe	5
2	Überblick der Anwendungen im Finanzwesen.....	6
2.1	Anwendungskonzepte auf mobilen Endgeräten (TR-03174, Teil 1, dieses Dokument)	6
2.1.1	Native-Anwendungen.....	6
2.1.2	Hybride Ansätze.....	6
2.2	Web-Anwendungen (TR-03174, Teil 2).....	6
2.3	Hintergrundsysteme.....	7
2.3.1	Selbst und extern gehostete Systeme.....	7
2.3.2	Cloud Computing.....	7
3	Security Problem Definition	8
3.1.1	Annahmen	8
3.1.2	Bedrohungen	8
3.1.3	Organisatorische Sicherheitspolitiken.....	9
3.1.4	Restrisiken.....	10
4	Empfehlungen.....	11
4.1	Anwendungszweck.....	11
4.2	Architektur.....	11
4.3	Quellcode.....	12
4.4	Drittanbieter-Software	13
4.5	Kryptographische Umsetzung.....	13
4.6	Authentisierung und Authentifizierung.....	14
4.7	Datensicherheit.....	15
4.8	Netzwerkkommunikation.....	16
4.9	Plattformspezifische Interaktion.....	16
4.10	Resilienz	17
5	Anforderungen an die Prüfung.....	18
5.1	Protokollierung der Prüfungsergebnisse	18
5.2	Risikoanalyse und -bewertung.....	19
	Anhang A: Schutzbedarf sensibler Datenelemente.....	21
	Anhang B: Prüftabellen.....	22
	Abkürzungsverzeichnis.....	23
	Literaturverzeichnis	24

Tabellenverzeichnis

Tabelle 1: Begriffe der Technischen Richtlinie.....	5
Tabelle 2: Anwendungszweck	11
Tabelle 3: Architektur	11
Tabelle 4: Quellcode.....	12
Tabelle 5: Drittanbieter-Software	13
Tabelle 6: Kryptographische Umsetzung.....	13
Tabelle 7: Authentisierung und Authentifizierung	14
Tabelle 8: Datensicherheit.....	15
Tabelle 9: Netzwerkkommunikation.....	16
Tabelle 10: Plattformspezifische Interaktion.....	16
Tabelle 11: Resilienz.....	17
Tabelle 12: Prüftiefen und Mindestanforderungen.....	18
Tabelle 13: Mögliche Prüfergebnisse	19
Tabelle 14: Anforderung anhand der Daten-Kritikalität.....	20
Tabelle 15: Schutzbedarf sensibler Datenelemente.....	21

1 Einleitung

1.1 Gegenstand der Technischen Richtlinie

Das Bundesamt für Sicherheit in der Informationstechnik [BSI] verfügt mit den IT-Grundschutzbausteinen und diversen Technischen Richtlinien [TR] über Umsetzungshilfen, um Anwendungen und IT-Infrastrukturen nach dem Stand der Technik abzusichern. Die vorliegende TR soll bei der Erstellung von mobilen Anwendungen im Finanzumfeld mit einer kompakten Übersicht möglicher technischer Maßnahmen zur Informationssicherheit unterstützen. Die TR richtet sich vor allem an einen nicht regulierten, heterogenen Adressatenkreis von Entwicklern und Anbietern mobiler Anwendungen, Web-Anwendungen und deren Hintergrundsysteme im finanznahen Umfeld, beispielsweise digitale Haushalts- und Kassenbücher, Steuer-, Finanz- und Kreditrechner sowie Apps mit Bezahlfunktion von Discounter.

Die Hinweise und Empfehlungen der TR stellen keine regulatorischen Pflichten dar. Für Finanzunternehmen, die einer Regulierung unterliegen, kann diese TR als eine Orientierungshilfe bei der Umsetzung der regulatorischen Vorgaben dienen. Europäische (z.B. [PSD2], [DORA], etc.) und / oder nationale Vorgaben (z.B. Rundschreiben der Bundesanstalt für Finanzdienstleistungsaufsicht [BaFin]) haben Vorrang vor den Empfehlungen der TR. Die alleinige Umsetzung der TR entbindet daher nicht von der zusätzlichen, weiterführenden Auseinandersetzung mit regulatorischen und weiteren technischen Vorgaben.

1.2 Übersicht der Technischen Richtlinie

1.2.1 Aufbau

Anwendungen im Sinne dieser TR sind Applikationen auf mobilen Endgeräten, entsprechend der Definition in Kapitel 2. Kapitel 3 zeigt Annahmen, Bedrohungen und organisatorische Sicherheitspolitiken auf, welche als Hintergrundinformation für die weitere Anwendung der TR dienen. In Kapitel 4 werden die Empfehlungen an eine mobile Anwendung aufgelistet, Kapitel 5 zeigt das Vorgehen der Auditierung der Umsetzung dieser Empfehlungen auf. Anhang A gibt Beispiele für den Schutzbedarf, welcher zur Risikobewertung existenziell ist. Die Tabellen der Anlage B können bei der Auditierung genutzt werden.

1.2.2 Begriffe

Diese Technische Richtlinie verwendet folgende Begriffe:

Tabelle 1: Begriffe der Technischen Richtlinie

Begriff	Beschreibung
MUSS	Die Anwendung muss eine bestimmte Eigenschaft zwingend aufweisen.
DARF NICHT / DARF KEIN(E)	Die Anwendung darf eine bestimmte Eigenschaft unter keinen Umständen aufweisen.
SOLL	Die Anwendung muss eine bestimmte Eigenschaft aufweisen, außer es wird dargelegt, dass durch ein Nicht-Umsetzen kein Risiko für den sicheren Betrieb besteht, bzw. eine Umsetzung, aufgrund von technischen Einschränkungen, derzeit nicht möglich ist.
KANN	Die Anwendung kann eine bestimmte Eigenschaft aufweisen, wobei ein Umsetzen dieser Eigenschaft vom Entwickler / Anbieter anzuzeigen ist.

2 Überblick der Anwendungen im Finanzwesen

2.1 Anwendungskonzepte auf mobilen Endgeräten (TR-03174, Teil 1, dieses Dokument)

Der Begriff „mobile Anwendung“ bezeichnet ein Programm, das auf einer mobilen Plattform ausgeführt wird. Grundsätzlich lassen sich solche Anwendungen in drei Kategorien unterteilen:

1. Native Anwendungen, zugeschnitten auf die Plattform, auf der sie ausgeführt werden,
2. Web-Anwendungen, plattformunabhängige Implementierung, laufen im Web-Browsers,
3. Hybride Ansätze, Kombinationen aus nativen Anwendungen und Web-Anwendungen.

Da mobile Anwendungen weit über den Einsatz von Web-Anwendungen in mobilen Browsern oder hybriden Anwendungen hinausgehen, liegt der Fokus dieser TR auf nativen Anwendungen und dem nativen Teil von hybriden Ansätzen.

2.1.1 Native-Anwendungen

Eine native Anwendung ist passend auf eine Plattform und deren Betriebssystem (beispielsweise Android oder [iOS]) zugeschnitten. Sie basiert auf den bereitgestellten Programmierwerkzeugen (Software Development Kits [SDK]). Diese ermöglichen einen direkten Zugriff auf Gerätekomponenten, wie beispielsweise [GPS], Kamera oder Mikrofon. Aufgrund ihrer Nähe zum Betriebssystem können sie eine gute Performanz, hohe Zuverlässigkeit und intuitive Bedienbarkeit erreichen. Die Anwendungen werden beispielsweise über den plattformeigenen [App]-Store installiert und können oft auch offline betrieben werden. Die Nähe zum Betriebssystem ist auch mit Nachteilen verbunden. Änderungen am Betriebssystem, beispielsweise durch Updates, können dazu führen, dass Anpassungen an der Anwendung vorgenommen werden müssen. Darüber hinaus ist es nicht möglich sie auf anderen Betriebssystemen zu installieren.

2.1.2 Hybride Ansätze

Hybride Anwendungen verbinden sowohl die Vor-, als auch die Nachteile von nativen Anwendungen und Web-Anwendungen. Mit Hilfe des SDKs wird eine Art „Rahmen-Anwendung“ geschaffen. Sie kann auf Gerätekomponenten zugreifen und über einen App-Store bezogen, jedoch nicht auf anderen Plattformen installiert werden, ohne Anpassungen am Quellcode vorzunehmen. Darüber hinaus beinhalten die Rahmen-Anwendungen einen eingebetteten Web-Browser, mit dessen Hilfe Web-Anwendungen in native Anwendungen eingebunden werden können. Dadurch ist es auch Web-Anwendungen möglich, auf die sonst nur den nativen Anwendungen vorbehaltenen Gerätekomponenten zuzugreifen. Allerdings müssen dabei Einbußen bei der Performanz und Stabilität in Kauf genommen werden.

2.2 Web-Anwendungen (TR-03174, Teil 2)

Web-Anwendungen sind Anwendungsprogramme, meist Webseiten, die in Kombination mit einem Hintergrundsystem (Kapitel 2.3) ohne Installation auf einem lokalen System betrieben werden können. Solche Webseiten sind oft so programmiert, dass sie wie eine native Anwendung für klassische Desktop-Systeme oder mobile Endgeräte aussehen und sich vergleichbar verhalten. Im Gegensatz zu nativen Anwendungen basieren sie nicht auf einem SDK der zugrundeliegenden Plattformen, sondern auf klassischen Programmierwerkzeugen der Web-Entwicklung. In den meisten Fällen kommen [HTML5] und JavaScript zum Einsatz. Aus diesem Grund ist mit ihnen nur ein sehr eingeschränkter Zugriff auf Gerätekomponenten möglich. Ihr größter Vorteil besteht darin, dass sie unabhängig vom Betriebssystem sind. Da die Anwendungen innerhalb eines Web-Browsers laufen, können sie auf jeder Plattform gleichermaßen eingesetzt werden, ohne Anpassungen an der Codebasis vornehmen zu müssen.

2.3 Hintergrundsysteme (TR-03174, Teil 3)

Viele Anwendungen lagern die Verarbeitung und Speicherung von Daten auf ein Server- bzw. Hintergrundsystem aus. Darüber hinaus übernehmen diese Systeme oft Aufgaben zur Authentifizierung und Autorisierung von Nutzern oder andere zentrale Tätigkeiten. Dies erlaubt es, dass nicht alle Funktionalitäten der Anwendungen auf den Endgeräten umgesetzt werden müssen. Die Ausprägungen können variieren. Daher ist bei vollumfänglicher sicherheitstechnischer Betrachtung der gesamten Anwendung die Sicherheit des Hintergrundsystems essentiell. Für die Nutzung von Anwendungen, die an ein Hintergrundsystem angeschlossen sind, ist meistens eine aktive Internetverbindung zwingend erforderlich. Dabei wird für die Kommunikation zwischen Front- und Backend-Systemen häufig eine über [TLS] gesicherte Transportverbindung eingesetzt.

Der Einsatz von Hintergrundsystemen wird im wesentlichen in drei Szenarien unterschieden:

1. Der Anbieter der Anwendung verwaltet das Hintergrundsystems selbst.
2. Der Anbieter lässt das Hintergrundsystem von einem Dienstleister verwalten.
3. Das gesamte Hintergrundsystem wird bei einem Cloud-Dienstleister gehostet.

Eine Trennung zwischen Web-Anwendung und Hintergrundsystem ist aufgrund der Abhängigkeiten kaum möglich. Daher muss bei einer solchen Architektur zusätzlich die TR-03174 „Sichere Anwendungen im Finanzwesen Teil 3: Hintergrundsysteme“ [TR03174-3] beachtet werden.

2.3.1 Selbst und extern gehostete Systeme

Bei selbst gehosteten Systemen agiert der Entwickler des Hintergrundsystems als Betreiber. Damit hat er den direkten Zugriff auf die Systeme. Die Server, auf denen das Hintergrundsystem betrieben wird, sind innerhalb der Betriebsumgebung des Herstellers untergebracht und die physische, technische und organisatorische Absicherung der Systeme erfolgt durch ihn alleine. Der Vorteil dieser Lösung besteht darin, dass der Hersteller alleine und unverzüglich auf jegliche Vorgänge reagieren kann. Da er die Systeme selber verwaltet und die Softwarekomponenten selber auswählt bzw. entwickelt, hat er am meisten Wissen über die mögliche Verwundbarkeit der Systeme. Allerdings lastet in diesem Fall auch die alleinige Verantwortung auf dem Hersteller, sodass er z.B. dauerhaft Personal abstellen muss, um Sicherheitsvorfälle zu überwachen.

Bei extern gehosteten Systemen werden die Server in einem Datacenter eines externen Dienstleisters gehostet. Die Vorteile bei dieser Lösung bestehen darin, dass der Dienstleister in der Regel mehr Erfahrung mit dem Betrieb solcher Systeme hat. Je nach Ausgestaltung übernimmt der externe Hoster auch weitergehende Aufgaben, wie z.B. die Versorgung der Betriebssysteme mit Sicherheitsupdates, Datensicherung und Backups, sowie Überwachung und Monitoring. Der Betreiber muss dem Hoster ein gewisses Maß an Vertrauen entgegenbringen, ihn aber auch steuern und überwachen. Der Hoster muss darauf achten, dass die Daten der einzelnen Kunden und Systeme voneinander separiert sind. Durch die Aufteilung der Zuständigkeiten können zeitkritische Reibungsverluste entstehen.

2.3.2 Cloud Computing

Cloud Computing beschreibt ein Modell, das bei Bedarf zeitnah und mit wenig Aufwand geteilte Computerressourcen als Dienstleistung, etwa in Form von Servern, Datenspeicher oder Anwendungen, bereitstellt. Je nach Bedarf können Ressourcen flexibel angepasst werden. Dadurch hat der Hersteller der Anwendung weniger Einfluss auf die Ausführungsumgebung als bei einem einfachen Hosting. Das BSI empfiehlt beim Einsatz von Cloud Computing für Anwendungen im Sinne der TR auf Anbieter zurückzugreifen, welche die Anforderungen aus dem „Kriterienkatalog Cloud Computing“ des BSI [KCC-C5] erfüllen. Alternativ sind Anbieter mit vergleichbaren Testaten oder Zertifikaten zulässig (vgl. [TR03174-3]).

3 Security Problem Definition

Die Security Problem Definition beschreibt Annahmen, Bedrohungen und organisatorische Sicherheitspolitiken, die für mobile Anwendungen zur Erbringung der Sicherheitsleistung relevant sind. Diese müssen nicht abschließend sein und können nach den individuellen Anforderungen ergänzt werden.

3.1.1 Annahmen

A.Device	Das Gerät, auf der die Anwendung genutzt wird, wird vom Nutzer selbst betrieben und vor Schwachstellen geschützt, etwa durch Aktualisieren des Betriebssystems nach Bereitstellung der jeweiligen Updates. Die Sicherheit des Gerätes wurde nicht durch Veränderungen durch den Nutzer beeinträchtigt. Geräte, welche durch den Hersteller nicht weiterhin mit Sicherheitsupdates versorgt werden, werden nicht verwendet.
A.Source	Der Bezug der Anwendung und Ihrer Updates erfolgt ausschließlich über sichere Quellen, die der Hersteller zur Veröffentlichung seiner Anwendung bestimmt hat (z.B. App-Stores, herstellereigene Website). Die installierten Anwendungen werden regelmäßig auf Updates geprüft und aktualisiert.
A.Backend	Das Hintergrundsystem befindet sich in einer geschützten Umgebung. Es ist durch organisatorische und technische Maßnahmen sichergestellt, dass Angreifer sich keinen physischen Zugriff auf die Infrastruktur des Hintergrundsystems verschaffen können. Das Hintergrundsystem erfüllt die Anforderungen der „TR-03174 Sichere Anwendungen im Finanzwesen Teil 3: Hintergrundsysteme“ [TR03174-3].
A.OperatingSystem	Es werden nur die vom Betriebssystem bereitgestellten Funktionen und Komponenten genutzt, die für den rechtmäßigen Zweck der Anwendung erforderlich sind. Die mittels der erteilten Berechtigungen des Betriebssystems genutzten Funktionen vergrößern die Angriffsfläche nicht und werden als sicher angenommen. Dies trifft insbesondere für die kryptographischen Funktionen und Protokolle zu. Das Betriebssystem teilt keine sensiblen Daten der Anwendung ohne vorherige Zustimmung des Nutzers mit Dritten.

3.1.2 Bedrohungen

T.SensitiveData	Sensible Daten in der Technischen Richtlinie sind im Sinne des Anhang A zu verstehen. Ein Unbefugter erhält Zugriff auf solche sensiblen Daten in der Anwendung, etwa auf sensible Benachrichtigungen im Sperrbildschirm, unverschlüsselt gespeicherte Daten im Dateisystem oder Arbeitsspeicher. Dies umfasst auch, dass ein Angreifer auf verschlüsselte, sensible Daten, nach Analyse des Verschlüsselungsmechanismus, im Klartext zugreifen kann.
T.Auth	Ein Angreifer erhält unter einer fremden Nutzerkennung oder der Verwendung fremder Rollen- oder Gruppenzugehörigkeit Zugriff auf sensible Daten anderer Nutzer.
T.Eavesdropping	Einem Angreifer gelingt es, z.B. über eine unzureichend verschlüsselte/nicht-authentisierte Verbindung, über unzureichend authentifizierte Interprozess-Kommunikation [IPC]-Aufrufe ¹ den Nutzer zu belauschen. Beispielsweise kann ein Angreifer aufgrund mangelnder Prüfung von Zertifikatseigenschaften den Aufbau einer Transportverbindung ausnutzen, um an sensible Daten zu gelangen.

¹ IPC (vgl. englisch: *Interprocess Communication*) wird auf mobilen Geräten als Kommunikationskanal zwischen verschiedenen Anwendungen genutzt.

T.DevFunctions	Ein Angreifer nutzt in der Anwendung versteckte oder verbliebene Entwickler- bzw. Debuggingfunktionen zur Unterwanderung von Sicherheitsmaßnahmen.
T.Impersonation	Ein Angreifer erhält durch fehlende oder fehlerhafte Zugriffskontrollen oder durch Erraten von Zugriffsparametern unberechtigten Zugriff auf sensible Daten oder kostenpflichtige Funktionen eines anderen Nutzers.
T.InfoDisclosure	Ein Angreifer führt eine Analyse der Anwendung durch und findet Referenzen auf z.B. Entwicklerinstanzen, hartkodierte Testaccounts oder Daten zur Verwendung in Verschlüsselungsroutinen.
T.Integrity	Ein Angreifer ist in der Lage, Daten innerhalb eines Speichers oder über den Transportweg unbemerkt zu manipulieren oder zu löschen.
T.MemoryStructures	Ein Angreifer führt ein Reverse Engineering auf die Anwendung durch und ermittelt dadurch ungeschützte Datenstrukturen im Speicher, wodurch der Zugriff auf Schlüssel und sensible Daten möglich wird.

3.1.3 Organisatorische Sicherheitspolitiken

OSP.Authorization	Der Hersteller entwickelt ein Autorisierungskonzept, welches sowohl den lesenden, als auch den schreibenden Zugriff auf sensible Daten steuert. Die Zugriffsberechtigungen müssen so gewählt werden, dass ausschließlich für die Erfüllung des primären bzw. rechtmäßigen Zwecks erforderliche Rechte erteilt werden. Das Autorisierungskonzept muss unabhängig von der Authentifizierung implementiert werden.
OSP.CriticalUpdates	Der Hersteller überprüft und überwacht die Anwendung sowie die genutzte Drittanbieter-Software ² dauerhaft auf ausnutzbare Schwachstellen. Der Hersteller muss bei bekannt werden von Schwachstellen kurzfristig ein Update bereitstellen. Das Hintergrundsystem muss die Anwendung über das Update informieren und nach einer Übergangsfrist (Grace Period) die Benutzung der Anwendung in einer veralteten Version unterbinden.
OSP.DataSovereignty	Die Anwendung stellt die Datenhoheit des Nutzers sicher. Die Anwendung weist den Nutzer auf bestehende Risiken durch die Konfiguration seines Endgeräts hin und lässt ihn entscheiden, die Nutzung abubrechen. Auf Anforderung des Nutzers löscht die Anwendung bereits erfasste Daten auf allen lokalen Speichermedien. Sofern eine Anbindung der App an ein Hintergrundsystem besteht, fragt die App ein Löschen der Daten beim Hintergrundsystem an.
OSP.Disclosure	Der Hersteller bietet einen niederschweligen Prozess zum Melden von Schwachstellen an. Das heißt, er stellt leicht auffindbare Kontaktinformationen zur Sicherheits-Abteilung bereit und bietet eine Möglichkeit, um Schwachstellen anonym zu melden.
OSP.LibsIn	Von Drittanbieter-Software eingehende Daten sollen vor einer Verwendung in der Anwendung validiert werden (z. B. [XML]-Schemavalidierung, Prüfung auf ungültiges Encoding etc.). Ziel ist es, die Anwendung vor Angriffen durch bösartige Eingaben zu schützen.
OSP.LibsOut	Die Anwendung soll sensible Daten nicht im Klartext an Drittanbieter-Software weitergeben. Zulässig ist die Nutzung entsprechender Drittanbieter-Software für die Sicherung eines Kommunikationskanals oder eines lokalen Speichercontainers.

² Unter einer Drittanbieter-Software soll die Zusammenfassung von Funktionalitäten verstanden werden, die nicht in der Hoheit des Entwicklers der Anwendung entstanden sind und die auch nicht Teil der Funktionalität der verwendeten Betriebssystemplattform ist.

OSP.Purpose	Jegliche Datenerhebung, -verarbeitung, -speicherung, -weitergabe und -löschung darf nur mit einer Zweckbindung erfolgen. Der Hersteller veröffentlicht dafür den rechtmäßigen Zweck der Anwendung und darüber hinaus welche Daten wie verarbeitet werden und wo und wie lange sie gespeichert werden. Ausgehend vom rechtmäßigen Zweck ist das zulässige Kommunikationsverhalten sowie die verwendete interne und externe Sensorik auszuwählen.
OSP.RNG	Zufallszahlen sind aus einem Zufallszahlengenerator zu beziehen, der eine hohe Entropie besitzt. Die Anwendung soll initial einmalig Entropie vom Nutzer in den Zufallszahlengenerator der Plattform einbringen. Anschließend bezieht die Anwendung Zufall vom Hintergrundsystem und bringt diese in den lokalen Zufallszahlengenerator ein.
OSP.SecurityLifeCycle	Der Hersteller realisiert einen Entwicklungszyklus, dessen Teilschritte darauf ausgelegt sind, die Sicherheit der Anwendung zu stärken. Darunter fallen Maßnahmen, mit denen böartige Aktivitäten erkannt werden und der Betreiber angemessene Gegenmaßnahmen einleiten kann.
OSP.SecurityLog	Sofern eine Anbindung der App an ein Hintergrundsystem besteht, werden Logs zu Sicherheitsvorfällen an das Hintergrundsystem geschickt.

3.1.4 Restrisiken

Mobile Endgeräte sind besonders anfällig für Diebstahl. Auch bei der Nutzung der sicheren Quellen (s.o.) ist nicht ausgeschlossen, dass auf diesen Quellen Schadsoftware zum Download angeboten wird. Installierte Schadsoftware kann bestehende Schwachstellen ausnutzen.

Der Betrieb des Hintergrundsystems bei Public Cloud-Anbietern beinhaltet besondere Risiken für die sensiblen Daten der Nutzer (siehe Teil 3 der TR-03174).

Der Schutz von Kommunikationsverbindungen zwischen der Plattform, der Anwendung und dem Hintergrundsystem könnte ebenfalls Schwachstellen und Risiken beinhalten. Diesem ist besondere Aufmerksamkeit sowohl in der Planung und Erstellung, als auch bei der Auditierung zu widmen.

Im Allgemeinen ist auf Grund der in Kapitel 2.1 und 2.3 beschriebenen Einschränkungen, bezogen auf den Umfang der Technischen Richtlinie, eine gesamtheitliche Aussage über die Sicherheit der Anwendung, selbst unter Berücksichtigung aller aufgeführten Prüf Aspekte, nicht möglich. Um die Sicherheit der gesamten Anwendung zu erhöhen, ist es erforderlich weitere Literatur zu studieren. Dies gilt insbesondere für den Schutz vor Angriffen, welche direkt das eingesetzte Hintergrundsystem als Ziel haben.

4 Empfehlungen

Im Folgenden sind die Empfehlungen an eine Mobile Anwendung im Finanzwesen aufgeführt. Diese basieren auf technische Empfehlungen und teilweise regulatorischen Vorgaben, deren Umsetzung für die Informationssicherheit von großer Bedeutung sind. Prüfkriterium und -tiefe (Anlage B) leiten sich aus diesen Empfehlungen ab. Diese müssen bei individuellen Anforderungen oder Bedrohungen, welche über den Standard hinausgehen, ergänzt werden.

4.1 Anwendungszweck

Tabelle 2: Anwendungszweck

Kürzel	Empfehlungen
O.Purp_1	Der Hersteller MUSS die rechtmäßigen Zwecke der Anwendung und die Verarbeitung von personenbezogenen Daten dem Nutzer gegenüber offenlegen (z.B. in den Nutzungsbedingungen).
O.Purp_2	Zur Wahrung der Datensparsamkeit und Zweckbindung DARF die Anwendung KEINE Daten erheben und verarbeiten, die nicht dem rechtmäßigen Zweck der Anwendung dienen bzw. für diesen notwendig sind.
O.Purp_3	Die Anwendung MUSS es ermöglichen, dass der Nutzer eine bereits in der Anwendung erteilte Einwilligung widerrufen und entziehen kann. Der Nutzer MUSS vor der Einwilligung über die Möglichkeit des Widerrufs und die sich daraus ergebenden Veränderungen im Verhalten der Anwendung informiert werden. Erhobene, personalisierte Sicherheitsmerkmale MÜSSEN nach einem Widerruf sowie einer Deaktivierung sicher vernichtet werden.
O.Purp_4	Die Anwendung SOLL eine Übersicht zur Überwachung und zum Management der in der Anwendung erteilten Berechtigungen zur Verfügung stellen.
O.Purp_5	Setzt die Anwendung Drittanbieter-Software ein, MÜSSEN alle verwendeten Funktionen für die rechtmäßigen Zwecke der Anwendung erforderlich sein. Die Anwendung MUSS anderweitige Funktionen sicher deaktivieren.
O.Purp_6	Wurde die Geschäftsbeziehung online in der Anwendung abgeschlossen MÜSSEN die zugehörigen Vertragsbedingungen ebenfalls in der Anwendung bereitgestellt werden.
O.Purp_7	Jegliche Meldung der Anwendung SOLL für den Nutzer verständlich und nachvollziehbar sein.
O.Purp_8	Die Anwendung SOLL dem Nutzer barrierearme Best-Practice-Empfehlungen zum sicheren Umgang mit der Anwendung und ihrer Konfiguration bereitstellen.

4.2 Architektur

Tabelle 3: Architektur

Kürzel	Empfehlungen
O.Arch_1	Informationssicherheit MUSS ein fester Bestandteil des Softwareentwicklungs- und Lebenszyklus für die gesamte Anwendung und das Hintergrundsystem sein.
O.Arch_2	Die Entwickelnden SOLLEN die Softwarearchitektur der Anwendung mit allen Bestandteilen und Abhängigkeiten dokumentieren. Die Dokumentation SOLL während des gesamten Entwicklungsverlaufs aktualisiert und angepasst werden. Die Dokumentation SOLL so gestaltet sein, dass Entscheidungen nachvollziehbar sind. In der Dokumentation SOLL beschrieben sein, welche Komponenten welche Sicherheitsmechanismen umsetzen, wie die Anwendung in eine bestehende Infrastruktur integriert wird und welche kryptografischen Funktionen und Verfahren eingesetzt werden.

O.Arch_3	Der Lebenszyklus von kryptographischem Schlüsselmaterial MUSS einer ausgearbeiteten Richtlinie folgen, die Eigenschaften wie die Zufallszahlenquelle, detaillierte Angaben zur Aufgabentrennung von Schlüsseln, Ablauf von Schlüsselzertifikaten, Integritätssicherung durch Hash-Algorithmen, etc., umfasst. Die Richtlinie SOLL auf anerkannten Standards wie [TR02102-2] und [NIST80057] basieren.
O.Arch_4	In Backups gespeicherte sensible Daten SOLLEN gemäß dem aktuellen Stand der Technik verschlüsselt sein. Dies schließt das Persistieren sensibler Daten durch den Browser, etwa in dessen Cache, mit ein.
O.Arch_5	Sicherheitsfunktionen MÜSSEN immer auf allen Außenschnittstellen und API-Endpunkten implementiert werden.
O.Arch_6	Die Anwendung SOLL die Überprüfung der Integrität durch eine digitale Signatur ermöglichen. Die Authentizität der Anwendung ist durch die Vertrauenswürdigkeit der Bezugsquelle sichergestellt.
O.Arch_7	Nutzt die Anwendung Drittanbieter-Software, MUSS der Hersteller sicherstellen, dass nur solche Drittanbieter-Software zum Einsatz kommt, deren Funktionen sicher genutzt werden können und dem Nutzer Informationen über den Nutzungsumfang und die eingesetzten Sicherheitsmechanismen transparent dargestellt wird. Die Anwendung MUSS sicherstellen, dass ungenutzte Funktionen deaktiviert sind.
O.Arch_8	Interpretierter Code, der in möglichen Interaktionen mit Benutzereingaben steht (WebViews mit JavaScript), SOLL KEINEN Zugriff auf verschlüsselte Speicher oder Nutzerdaten haben, sofern es für die Erfüllung des primären Zwecks der Anwendung nicht zwingend erforderlich ist.
O.Arch_9	Der Hersteller SOLL dem Nutzer eine barrierearme Möglichkeit bereitstellen, um Sicherheitsprobleme zu melden. Die Kommunikation SOLL über einen verschlüsselten Kanal oder den persönlichen Kontakt, z.B. telefonisch, stattfinden.
O.Arch_10	Die Anwendung SOLL beim Start auf verfügbare sicherheitsrelevante Updates prüfen. Wenn ein sicherheitsrelevantes Update verfügbar ist, SOLL die Anwendung sensible Daten NICHT mehr verarbeiten, ohne dieses Update einzuspielen. Der Nutzer MUSS über die Möglichkeit eines Updates und über ein durchgeführtes Update informiert werden.
O.Arch_11	Der Hersteller MUSS für die Veröffentlichung der Anwendung (und ihrer Updates) eine Quelle wählen, auf der die Anwendung gegen Manipulation durch Unbefugte geschützt ist und die einen vertrauenswürdigen Kanal zum Bezug der Anwendung zur Verfügung stellt.
O.Arch_12	Der Hersteller MUSS dem App-Nutzer einfach und sicher zugängliche Wege zum Bezug der Anwendung bereitstellen (z.B. in Form einer Link-Liste auf seiner Website, als individuell zugestellter QR-Code, o. Ä.).
O.Arch_13	Bevor eine App für den Einsatz freigegeben wird, SOLL ein Penetrationstest durchgeführt werden. Dabei SOLLEN alle Kommunikationsschnittstellen zu Backend-Systemen sowie die lokale Speicherung von Daten auf mögliche Sicherheitslücken untersucht werden. Die Penetrationstests SOLLEN regelmäßig und zusätzlich bei größeren Änderungen an der App wiederholt werden.

4.3 Quellcode

Tabelle 4: Quellcode

Kürzel	Empfehlungen
O.Source_1	Die Anwendung MUSS alle Eingaben vor deren Verarbeitung prüfen, um potenziell bösartige Werte vor der Verarbeitung herauszufiltern.
O.Source_2	Die Anwendung MUSS eingehende und ausgehende Daten maskieren, beziehungsweise von potenziell schadhaften Zeichen bereinigen oder deren Verarbeitung ablehnen.

O.Source_3	Fehlermeldungen und Log-Dateien DÜRFEN KEINE sensiblen Daten (z. B. User Identifier oder Session-IDs) enthalten. Eine fehlgeschlagene Authentifizierung DARF KEINE Rückschlüsse auf Elemente der Authentifizierung zulassen.
O.Source_4	Potenzielle Ausnahmen im Programmablauf (Exceptions) MÜSSEN abgefangen, kontrolliert behandelt und dokumentiert werden. Technische Fehlerbeschreibungen (z.B. Stack Traces) DÜRFEN dem Nutzer NICHT angezeigt werden. Die Rückantworten und Fehlermeldungen der Anwendung DÜRFEN KEINE Informationen enthalten, die Angreifenden Hinweise darauf geben, wie man Sicherheitsmechanismen umgehen kann.
O.Source_5	Bei Ausnahmen im Programmablauf (Exceptions) SOLL die Anwendung Zugriffe auf sensible Daten abbrechen und diese im Speicher sicher löschen.
O.Source_6	Alle Optionen zur Unterstützung der Entwicklung (z. B. Entwickler-URLs, Testmethoden, Überreste von Debugmechanismen etc.) MÜSSEN in der Produktiv-Version vollständig entfernt sein.
O.Source_7	Für die Entwicklung der Anwendung SOLLEN Werkzeuge zur statischen Codeanalyse eingesetzt werden.
O.Source_8	Es MUSS sichergestellt sein, dass die Nutzer Dateien nur im von der Anwendung vorgesehenen Pfad speichern können.

4.4 Drittanbieter-Software

Tabelle 5: Drittanbieter-Software

Kürzel	Empfehlungen
O.TrdP_1	Der Anbieter MUSS eine zentrale und vollständige Liste von Abhängigkeiten durch Drittanbieter-Software führen.
O.TrdP_2	Drittanbieter-Software MUSS in der neuesten oder der ihr vorhergehenden, für die Veröffentlichung vorgesehenen Version verwendet werden.
O.TrdP_3	Drittanbieter-Software MUSS durch den Hersteller regelmäßig auf Schwachstellen überprüft werden. Überreste von Optionen zur Unterstützung der Entwicklung sind hierbei als Schwachstelle zu werten. Der Hersteller MUSS für alle öffentlich bekannten Schwachstellen analysieren, inwieweit die Schwachstelle die Sicherheit des Gesamtsystems beeinträchtigt. Software, bzw. Funktionen aus Drittanbieter-Software DÜRFEN bei bekannten Schwachstellen, die die Sicherheit des Gesamtsystems betreffen, NICHT eingesetzt werden.
O.TrdP_4	Sicherheitsupdates für Drittanbieter-Software MÜSSEN zeitnah integriert und per Update dem Nutzer zur Verfügung gestellt werden.
O.TrdP_5	Vor der Verwendung von Drittanbieter-Software MUSS deren Quelle auf Vertrauenswürdigkeit geprüft werden.
O.TrdP_6	Über Drittanbieter-Software eingehende Daten MÜSSEN validiert werden.
O.TrdP_7	Drittanbieter-Software, die nicht mehr gewartet wird, DARF NICHT verwendet werden.

4.5 Kryptographische Umsetzung

Tabelle 6: Kryptographische Umsetzung

Kürzel	Empfehlungen
O.Cryp_1	Beim Einsatz von Verschlüsselung in der Anwendung DÜRFEN KEINE fest einprogrammierten geheimen, bzw. privaten Schlüssel eingesetzt werden.
O.Cryp_2	Die Anwendung MUSS auf bewährte Implementierungen zur Umsetzung kryptographischer Primitive und Protokolle zurückgreifen (vgl. [TR02102-2]).

O.Cryp_3	Die Wahl kryptographischer Primitive MUSS passend zum Anwendungsfall sein und dem aktuellen Stand der Technik (siehe [TR02102-1]) entsprechen. Die Vertraulichkeit, z.B. der Authentifizierungsmerkmale, MUSS zu jedem Zeitpunkt gewährleistet sein.
O.Cryp_4	Kryptographische Schlüssel DÜRFEN NICHT für mehr als genau einen Zweck eingesetzt werden.
O.Cryp_5	Die Stärke der kryptographischen Schlüssel MUSS dem aktuellen Stand der Technik entsprechen (siehe [TR02102-1]).
O.Cryp_6	Das geheime kryptografische Material MUSS vor unbefugter Offenlegung geschützt sein. Der Prozess zur Verschlüsselung SOLL vollständig dokumentiert sein.
O.Cryp_7	Alle kryptographischen Operationen SOLLEN in einer vor Manipulation und Offenlegung geschützten Umgebung stattfinden.
O.Cryp_8	Alle Zufallswerte MÜSSEN über einen starken kryptographischen Zufallszahlengenerator erzeugt werden.

4.6 Authentisierung und Authentifizierung

Tabelle 7: Authentisierung und Authentifizierung

Kürzel	Empfehlungen
O.Auth_1	Der Hersteller MUSS ein Konzept zur Authentisierung auf angemessenem Vertrauensniveau [TR03107-1], zur Autorisierung (Rollenkonzept) und zum Beenden einer Anwendungssitzung dokumentieren. Der Auswahlprozess der Authentisierungsmethode MUSS dokumentiert werden.
O.Auth_2	Ist eine Zwei-Faktor-Authentifizierung gefordert, z.B. aufgrund regulatorischer Vorgaben oder dem Umgang mit besonders schützenswerten Daten, MÜSSEN die Faktoren aus den Kategorien Wissen, Besitz und Inhärenz kommen, wobei die Faktoren aus unterschiedlichen Kategorien sein MÜSSEN . Die Faktoren MÜSSEN vor unbefugtem Zugriff bzw. Verwendung geschützt werden.
O.Auth_3	Der Nutzer MUSS über ungewöhnliche Anmeldevorgänge informiert werden.
O.Auth_4	Das IT-System bzw. die IT-Anwendung SOLL nach jedem erfolglosen Authentisierungsversuch weitere Anmeldeversuche zunehmend verzögern (Time Delay). Die Gesamtdauer eines Anmeldeversuchs SOLL begrenzt werden können. Nach Überschreitung der vorgegebenen Anzahl erfolgloser Authentisierungsversuche SOLL das IT-System bzw. die IT-Anwendung die Benutzendenkennung sperren.
O.Auth_5	Die Anwendung MUSS nach einer angemessenen Zeit in der sie nicht aktiv verwendet oder unterbrochen wurde eine erneute Authentisierung fordern. Alle alten Sitzungsdaten SOLLEN ungültig und gelöscht sein. Diese Regelungen sollen auch für die Verbindung zum Hintergrundsystem gelten.
O.Auth_6	Die Authentisierungsdaten DÜRFEN NICHT ohne eine erneute Authentifizierung des Nutzers geändert werden.
O.Auth_7	Die Anwendung MUSS für die Anbindung eines Hintergrundsystems eine dem Stand der Technik entsprechende Authentifizierung verwenden.
O.Auth_8	Authentisierungsdaten, wie bspw. Session-IDs bzw. Authentisierungstoken, MÜSSEN als sensible Daten geschützt werden. Session-IDs MÜSSEN zufällig und mit ausreichender Entropie erzeugt werden. Wenn Session-IDs übertragen und von den Clients gespeichert werden, MÜSSEN sie ausreichend geschützt übertragen werden.
O.Auth_9	Wird eine Anwendungssitzung ordnungsgemäß beendet, MUSS die Anwendung das Hintergrundsystem darüber informieren, sodass Session-Identifizier bzw. Authentisierungstoken sicher gelöscht werden. Dies gilt sowohl für das aktive Beenden durch den Benutzer (log-out), als auch für das automatische Beenden durch die Anwendung.

O.Auth_10	Bei Änderung der Zugangsparameter MUSS der Nutzer über die zuletzt hinterlegten, gültigen Kontaktdaten über die Änderung informiert werden. Dem Nutzer SOLL über diesem Weg eine Möglichkeit geboten werden, die gemeldete Änderung zu sperren und nach entsprechender Authentifizierung neue Zugangsparameter zu setzen.
O.Pass_1	Bei einer Authentifizierung mittels dem Faktor Wissen (Benutzername und Passwort) SOLLEN Passwortrichtlinien, also Vorgaben an die Art und Qualität des Passwortes, existieren. Diese SOLLEN sich am aktuellen Stand gängiger „Best-Practices“ orientieren.
O.Pass_2	Für die Einrichtung der Authentisierung mittels Benutzername und Passwort KANN die Stärke des verwendeten Passworts dem Nutzer angezeigt werden. Informationen über die Stärke des gewählten Passworts DÜRFEN NICHT gespeichert werden.
O.Pass_3	Der Nutzer MUSS die Möglichkeit haben, sein Passwort zu ändern.
O.Pass_4	Wird die Anwendung zusammen mit einem Hintergrundsystem genutzt, SOLL das Ändern und Zurücksetzen von Passwörtern protokolliert werden. Das Hintergrundsystem SOLL den Nutzer über das Ändern und Zurücksetzen von Passwörtern informieren, dabei SOLL ein separater Kanal genutzt werden.
O.Pass_5	Werden Passwörter gespeichert, MÜSSEN diese gemäß den aktuellen Sicherheitsstandards geschützt werden.
O.Pass_6	Die Anwendung DARF sensible Daten NICHT auf dem Bildschirm darstellen, außer dies ist für den primären Zweck der Anwendung erforderlich oder wird durch den Nutzenden explizit ausgewählt.

4.7 Datensicherheit

Tabelle 8: Datensicherheit

Kürzel	Empfehlungen
O.Data_1	Die Werkseinstellung der Anwendung MUSS die maximale Sicherheit bieten.
O.Data_2	Vertrauliche Daten innerhalb der Anwendung MÜSSEN durch sichere, kryptografische Algorithmen abgesichert werden.
O.Data_3	Die Anwendung MUSS sensible Daten verschlüsselt speichern. Die betriebssystemeigene Verschlüsselung des Dateisystems genügt nicht. Das Schlüsselmaterial für diese Verschlüsselung DARF NICHT unverschlüsselt persistiert werden. Dies gilt sowohl für flüchtiges Ablegen (z. B. im Arbeitsspeicher), als auch für dauerhaftes Speichern (z. B. in einer Cloud-Umgebung). Eine hardwareunterstützte Schlüsselverwaltung der Plattform SOLL bevorzugt verwendet werden.
O.Data_4	Die Anwendung SOLL sensible Daten in einem vor Einsicht und Manipulation besonders geschützten Bereich ablegen.
O.Data_5	Alle erhobenen sensiblen Daten DÜRFEN NICHT über die Dauer ihrer jeweiligen Verarbeitung hinaus in der Anwendung gehalten werden.
O.Data_6	Die Anwendung MUSS die Grundsätze der Datensparsamkeit und Zweckbindung berücksichtigen.
O.Data_7	Bei der Eingabe sensibler Daten über die Tastatur SOLL die Anwendung unterbinden, dass Aufzeichnungen für Dritte erkennbar werden.
O.Data_8	Sensible Daten DÜRFEN clientseitig NICHT zwischengespeichert werden. Die Anwendung KANN alternativ eine eigene Zwischenablage implementieren, welche vor dem Zugriff durch andere Anwendungen geschützt ist
O.Data_9	Die Anwendung SOLL Funktionen des Betriebssystems zur Unterbindung der Anzeige sensibler Daten und des Zugriffs für Dritte und der Speicherung des Bildschirms (z. B. Screenshots und Anzeigen für das App-Switching) nutzen.
O.Data_10	Die Anwendung MUSS bei endgültiger Beendigung der Nutzung alle sensiblen Daten und anwendungsspezifische Anmeldeinformationen vollständig löschen bzw. unzugänglich machen.

O.Data_11	Die Anwendung SOLL dem Nutzer die Möglichkeit geben, dass alle sensiblen Daten und anwendungsspezifischen Anmeldeinformationen vollständig gelöscht bzw. unzugänglich gemacht werden.
O.Data_12	Um dem Missbrauch von sensiblen Daten nach einem Geräteverlust entgegenzuwirken, KANN die Anwendung einen Kill-Switch realisieren, d. h. ein absichtliches, sicheres Überschreiben von Nutzerdaten im Gerät auf Anwendungsebene, ausgelöst durch das Hintergrundsystem. Der Hersteller MUSS die Auslösung des Kill-Switches durch den Anwender über das Hintergrundsystem durch starke Authentifizierungsmechanismen vor missbräuchlicher Nutzung schützen.

4.8 Netzwerkkommunikation

Tabelle 9: Netzwerkkommunikation

Kürzel	Empfehlungen
O.Ntwk_1	Die Netzwerkkommunikation zwischen den Verbindungspartnern MUSS gegenseitig authentifiziert werden und die Kommunikation MUSS verschlüsselt erfolgen.
O.Ntwk_2	Die Konfiguration der verschlüsselten Verbindungen MUSS dem aktuellen Stand der Technik entsprechen (vgl. [TR02102-2]).
O.Ntwk_3	Die Anwendung SOLL Zertifikats-Pinning anwenden.
O.Ntwk_4	Die Anwendung MUSS das Server-Zertifikat des Hintergrundsystems überprüfen.
O.Ntwk_5	Die Anwendung MUSS die Integrität und Authentizität der Antworten des Hintergrundsystems validieren.
O.Ntwk_6	Plattformspezifische Optionen, wie beispielsweise „Cleartext Traffic Opt-out“ und „In-App Transport Security“ MÜSSEN verwendet werden.
O.Ntwk_7	Die Anwendung MUSS für alle Verbindungen Log-Dateien vorhalten. Diese SOLLEN an das Hintergrundsystem übermittelt werden.

4.9 Plattformspezifische Interaktion

Tabelle 10: Plattformspezifische Interaktion

Kürzel	Empfehlungen
O.Plat_1	Sicherheitsrelevante Berechtigungseinstellungen MÜSSEN so fixiert werden, dass sie nicht durch Personen oder Apps geändert werden können. Wo dies technisch nicht möglich ist, MÜSSEN die Berechtigungseinstellungen regelmäßig geprüft und erneut gesetzt werden.
O.Plat_2	Die Anwendung DARF Berechtigungen, die für die Erfüllung ihres primären Zwecks nicht notwendig sind, NICHT einfordern.
O.Plat_3	Die Anwendung MUSS den Nutzer auf den rechtmäßigen Zweck der anzufragenden Berechtigungen und auf die Auswirkungen hinweisen, die eintreten, falls der Nutzer diese nicht gewährt.
O.Plat_4	Die Anwendung DARF KEINE sensiblen Daten in erweiterten Meldungen oder Benachrichtigungen, die nicht vom Nutzer explizit eingeschaltet wurden, anzeigen.
O.Plat_5	Die Anwendung KANN dem Nutzer die Optionen bieten, erweiterte Meldungen und Benachrichtigungen, ggf. auch mit sensiblen Inhalten, anzuzeigen. Bei Werkseinstellung MUSS diese deaktiviert sein.
O.Plat_6	Die Anwendung MUSS Zugriffsbeschränkungen auf sensible Daten realisieren.
O.Plat_7	Die plattformspezifischen Mechanismen zur Interprozesskommunikation DÜRFEN NICHT zum Austausch von sensiblen Daten genutzt werden, sofern sie nicht zur Erfüllung des primären Zwecks der Anwendung erforderlich sind.

O.Plat_8	Ein abgebrochener Start SOLL als Sicherheitsereignis protokolliert werden. Die Protokollierung SOLL im Hintergrundsystem stattfinden.
O.Plat_9	Es muss eine Anforderungsanalyse erstellt werden. In dieser MÜSSEN insbesondere Risiken betrachtet werden, die sich aus der mobilen Nutzung ergeben. Die Institution MUSS prüfen, ob ihre Kontroll- und Einflussmöglichkeiten auf die Betriebssystemumgebung mobiler Endgeräte ausreichend sind, um sie sicher nutzen zu können.

4.10 Resilienz

Tabelle 11: Resilienz

Kürzel	Empfehlungen
O.Resi_1	Die Anwendung MUSS eigene Prüfmechanismen implementieren, die beim Start der Anwendung feststellen, ob sie in einer Entwicklungs-/Debug-Umgebung ausgeführt wird. Wenn die Anwendung feststellt, dass sie in einer Entwicklungs-/Debug-Umgebung ausgeführt wird, MUSS sie sich sofort beenden.
O.Resi_2	Die Anwendung MUSS eigene Prüfmechanismen implementieren, die beim Start der Anwendung feststellen, ob sie unter ungewöhnlichen Benutzerrechten gestartet ist. Wenn die Anwendung feststellt, dass dies der Fall ist, MUSS sie sich sofort beenden.
O.Resi_3	Die Anwendung MUSS vor dem Zugriff auf das Hintergrundsystem dessen Authentizität überprüfen.
O.Resi_4	Die Anwendung MUSS dem Stand der Technik entsprechende Maßnahmen gegen Reverse Engineering umsetzen.
O.Resi_5	Die Anwendung MUSS unterschiedliche Ausprägungen einer Plattform (bspw. Android) bei unterschiedlichen Herstellern berücksichtigen. Sie muss so gebaut sein, dass solche unterschiedlichen Plattformen bzw. unterschiedliche Plattformversionen zu keinem Fehlverhalten führt. Insbesondere MUSS ein missbräuchlicher Zugriff auf Ressourcen durch unterschiedliche Ausprägungen einer Plattform ausgeschlossen werden.
O.Resi_6	Die Anwendung SOLL robust gegenüber Störungen sein.

5 Anforderungen an die Prüfung

Die Prüfung mobiler Anwendungen im Finanzwesen orientiert sich an den Empfehlungen (Kapitel 4). Aus diesen werden Testcharakteristika und Prüftiefe abgeleitet, welche als Basis einer Prüfung dienen (siehe Anhang B). Unterstützend kann der Hersteller Aussagen tätigen, in denen er die betreffende Umsetzung skizziert und eine Referenz auf die jeweilige Implementierung angibt. Die untenstehende Tabelle legt dar, welche Prüfschritte mindestens für die jeweilige Prüftiefe gefordert sind.

Tabelle 12: Prüftiefen und Mindestanforderungen

Prüftiefe	Mindestanforderungen an die Prüfung
CHECK	Der Evaluator validiert (englisch „check“, analog Begriffsverwendung in der Common Criteria Evaluation Methodology) die vom Hersteller beschriebene Maßnahme im Hinblick auf ihre Wirksamkeit und räumt bestehende Zweifel (Plausibilitätsprüfung) aus, ob der Prüfaspekt und die damit verbundene Sicherheitsproblematik umfassend durch die beschriebenen Maßnahmen adressiert werden. Hierbei MUSS der Evaluator den aktuellen Stand der Technik berücksichtigen. Die Validierung KANN weitergehende Schritte, z.B. eine Quelltextanalyse, umfassen, falls der Evaluator diese für eine Einschätzung benötigt.
EXAMINE	Der Evaluator untersucht (englisch „examine“, analog zur Common Criteria Evaluation Methodology) die betreffende Testcharakteristik. Der Evaluator MUSS in seiner Prüfung über die Mindestanforderungen für „CHECK“ hinausgehen: In der Regel wird dies durch umfassende Quelltextanalyse der relevanten Implementierungsanteile und Penetrationstests geschehen. Die Unterstützung durch den Hersteller kann genutzt werden. „EXAMINE“ erfordert in jedem Fall eine eigenständige Beurteilung durch den Evaluator.

Bei Prüftiefe „CHECK“ wählt der Prüfer, wie hoch die Abdeckung der Analyse für seine Einschätzung notwendig ist. Für „EXAMINE“ muss der Prüfer erläutern, inwiefern sämtliche relevanten Codezeilen in Betracht gezogen wurden.

5.1 Protokollierung der Prüfungsergebnisse

Die Protokollierung der Testergebnisse ist so zu gestalten, dass unbeteiligte Dritte in die Lage versetzt werden, anhand der Angaben aus dem Prüfbericht die vorgenommenen Prüfschritte zu wiederholen und dabei das gleiche Ergebnis zu erzielen. Hierzu ist es neben der Beschreibung der einzelnen Prüfschritte notwendig, dass die verwendeten Prüfwerkzeuge in den verwendeten Versionen in dem Prüfbericht ersichtlich sind. Die untenstehende Tabelle definiert die zulässigen Prüfergebnisse, welche sich aus der Prüfung einer Charakteristik ergeben können. Der TR-Prüfer begründet, wie er zu einem entsprechenden Ergebnis gekommen ist.

Tabelle 13: Mögliche Prüfergebnisse

Ergebnis	Notwendige Angaben
PASS	Der Prüfer erläutert sein Verständnis, warum die Hersteller-Implementierung das geforderte Sicherheitsziel erfüllt. Der Prüfbericht führt die durchgeführten Prüfschritte sowie das Prüfergebnis aus.
INCONCLUSIVE	Der Prüfbericht spezifiziert/referenziert die fehlenden oder inkonsistenten Informationen, damit der Hersteller die Nicht-Konformität zu dem betreffenden Aspekt des Sicherheitsziel bereinigen kann.
FAIL	Die geprüfte Anwendung verfehlt das betreffende Sicherheitsziel. Der Prüfer dokumentiert, inwiefern Angriffe durch Sicherheitsmaßnahmen in der Umgebung der Anwendung (z.B. operative Maßnahmen) verhindert werden können. Der Prüfer nimmt eine Evidenz der Verletzung der Prüfcharakteristik in die Protokollierung auf. Der Prüfer nimmt das durch die Verletzung der Testcharakteristik entstehende Risiko in die Risikoabschätzung mit auf.
NOT APPLICABLE (N/A)	Die geprüfte Anwendung verfügt über keinerlei Implementierung der durch den Prüfaspekt zu schützenden Funktionalitäten. Daher kann die betreffende Testcharakteristik nicht auf die zu prüfende Anwendung angewandt werden.

5.2 Risikoanalyse und -bewertung

Die Prüfer identifizieren bestehende Restrisiken beim Einsatz der Anwendung im Finanzwesen. Mit der Aufdeckung bestehender Restrisiken wird dem Umstand Rechnung getragen, dass der Verlust von Finanzdaten zu einem Schaden für den Nutzer führt und ausreichende Schutzmaßnahmen zum Zeitpunkt der TR-Prüfung nicht identifiziert werden konnten. Die Risikobewertung muss mindestens folgende Aspekte umfassen:

- Identifikation von Risiken aus der unterlassenen oder unzureichenden Umsetzung von „SOLL“-Anforderungen in Sicherheitszielen.
- Implementierungsspezifische Risiken.
- Risiken durch Integration in der geplanten Betriebsumgebung.
- Berücksichtigung der Eignung des Monitorings sowie vorgesehene Reaktionsmöglichkeiten.

Grundlage für die Prüfung und das daraus resultierende Prüfurteil soll ein dokumentiertes Risikomanagementverfahren sein. Als allgemeine Referenz werden BSI Standard 200-3 [[BSI200-3], [ISO27005] und Anhang B der Common Criteria Evaluation Methodology [CCEM] genannt. Vergleichbare Risikomanagementverfahren sind möglich.

Die Prüfer führen eine methodische Risikoanalyse durch, die mindestens folgende Schritte umfassen muss:

1. Sicherheitsproblem vollständig aufarbeiten – Ausgangspunkt der Risikoanalyse sind die Bedrohungen, Annahmen und Sicherheitspolitiken der Anwendung (siehe Kapitel 3). Der Prüfer etabliert eine vollständige Liste aller sensiblen Daten, die in der Anwendung erfasst, erzeugt oder genutzt werden. Sensible Daten, die alleine im Hintergrundsystem verarbeitet werden, sind durch die Annahme A.Backend (siehe Kapitel 3.1.1) abgedeckt.
2. Schutzbedarf feststellen – die IT-Sicherheit betrachtet generell den Schutzbedarf hinsichtlich Vertraulichkeit, Integrität, Authentizität und Verfügbarkeit. Der Prüfer klassifiziert den jeweiligen Schutzbedarf aller verarbeiteten Daten, vgl. Anhang B in ISO 27005. Die Daten im Rahmen der TR werden anhand ihrer Kritikalität unterschieden (vgl. Tabelle 15).

3. Risikoszenarien bewerten – Der TR-Prüfer führt unter Berücksichtigung der etablierten Gegenmaßnahmen eine Bewertung von Risikoszenarien durch. Es muss dafür ein dokumentierter, ganzheitlicher Ansatz auf die sensiblen Daten der Anwendung durchgeführt werden, beispielsweise ISO 27005 , Abschnitt 8.3 und Anhänge C/D/E.

In die Bewertung durch den Prüfer geht ein, welche Schutzmaßnahmen im Produkt realisiert sind, und deren Effektivität. Ebenfalls werden Vorgaben für die sichere Nutzung berücksichtigt, sofern diese dem Nutzer ausreichend dargelegt sind. Ob das Sicherheitsproblem angemessen behandelt wird, schätzen die Prüfer anhand der Schwierigkeit ermittelter Angriffspfade ein (die Schwierigkeit eines Angriffs ersetzt dabei die in der ISO 27005 referenzierte Eintrittswahrscheinlichkeit eines Risikos).

Häufig werden für die Angriffsbewertung auf mobile Anwendungen folgende Bewertungsprinzipien eingesetzt:

1. Zeitbasierter Ansatz – Der Prüfer schätzt den zeitlichen Aufwand eines Angreifers zur Überwindung der Sicherheitsmaßnahmen ein. Der Hersteller versichert, dass vor Ablauf dieser Zeit eine neue Produktversion mit neuem Schlüsselmaterial bereitgestellt wird (z.B. spätestens monatlich) und die Anwendung ist so beschaffen, dass Angriffe nur an der aktuellsten Produktversion ausgeführt werden können. Die Ausnutzung der Schwachstelle wird so unterbunden.
2. Reaktiver Ansatz – Hier analysiert der Prüfer die effektive Bekämpfung der Risikoszenarien mittels proaktiven Monitorings inkl. Reaktion. Beispielsweise werden Betriebsparameter erfasst und der Zugriff auf sensible Daten abgewehrt, sofern diese auf absichtliche Modifikationen hindeuten. Extern vom Hersteller selbst-realisierte Schutzmechanismen müssen mitbetrachtet werden.

Der Prüfer muss aufgrund der ermittelten Restrisiken ein Urteil abgeben, inwiefern das von der TR adressierte Sicherheitsproblem adäquat erfüllt wird. Neben der Kompromittierung und dem Verlust von Daten spielt bei Anwendungen im Finanzwesen natürlich auch der unmittelbar mögliche finanzielle Schaden bei der Risikobewertung eine wichtige Rolle, die bei der Risikobewertung zu berücksichtigen ist.

Tabelle 14: Anforderung anhand der Daten-Kritikalität

Kritikalität	Beschreibung	Anforderung
Sehr hoch	Eine Verletzung des Schutzbedarfs führt zu einem nicht zu beziffernden oder potenziell schwerwiegenden Schaden für den Dateninhaber.	Die realisierten Maßnahmen werden als wirksam erachtet, sämtliche Risikoszenarien ohne Restrisiken auszuräumen.
Hoch	Eine Verletzung des Schutzbedarfs führt zu einem hohen oder mittleren Schaden für den Dateninhaber.	Die realisierten Maßnahmen reduzieren die Risikoszenarien erheblich. Der Prüfer muss die Durchführung verbleibender Angriffe bewerten und deren Auswirkungen dokumentieren. Im Einzelfall ist das Restrisiko darzustellen und kann Auflagen in der Nutzung der Zertifizierung verursachen.
Normal	Es kann höchstens ein geringer Schaden eintreten.	Die realisierten Maßnahmen reduzieren die Risikoszenarien. Der Prüfer muss die Durchführung verbleibender Angriffe bewerten und Restrisiken offenlegen.

Anhang A: Schutzbedarf sensibler Datenelemente

Abhängig von der realisierten Anwendung und der Kritikalität der jeweils verarbeiteten Datenelemente kann ein unterschiedlicher Schutzbedarf notwendig sein. Personenbezogene Daten unterliegen dem Datenschutz und dürfen nur bei Zweckbindung und nach Einverständnis verarbeitet werden. Die Sensibilität verarbeiteter Datenelemente wird in der folgenden Tabelle bestimmt.

Tabelle 15: Schutzbedarf sensibler Datenelemente

Information	Sensibel	Übertragung an Hintergrund system erlaubt	Ablage außerhalb sicherer Umgebung erlaubt	Bemerkungen
Anwendungsdaten	Ja	Ja	Ja	-
Eingabedaten (von extern, dritter Partei, einer Drittanbieter-Software, über Tastatur oder von Gerätesensoren)	Nein, falls nicht in anderer Kategorie speziell erfasst	Ja	Ja	Vorbehandlung, u.a. Größenprüfung, Escaping-Sequenzen (je nach Weiterverarbeitung)
Zugangsdaten	Ja	Ja	Ja	z.B. salted hashing. Zulässig ist Drittanbieter-Software für Authentifizierung.
Kryptographische Schlüssel der Anwendung	Ja	Nein	Nein ³	Zulässig ist die Nutzung in Drittanbieter-Software zur Kryptographie und Session-Handling.
Aggregierte Anwendungsdaten	Ja	Ja	Ja	
Biometrische Daten	Ja	Nein	Nein ⁴	Biometrische Daten sind der Anwendung nicht zugänglich, außer einem Referenzmerkmal (z.B. User 1).

³ Ausgenommen sind Public Keys oder kryptografische Schlüssel von Drittanbietersoftware, sofern diese nicht der Kontrolle des Anwendungs-Entwicklers unterliegen und mobile Endgeräte, die nicht über eine sichere Umgebung (z. B. embedded Secure Element/Secure Enclave/Trusted Execution Environment) verfügen.

⁴ Automatisch erfüllt, wenn das Betriebssystem der Anwendung diese Daten nicht zur Verfügung stellt, andernfalls müssen die Daten als sensible Daten von der Anwendung geschützt werden

Anhang B: Prüftabellen

Maßgeblich für die Überprüfung der mobilen Anwendung sind die Anforderungen aus Kapitel 4. Diese werden um

- die Prüfaspekte
- die Prüftiefe sowie
- weiterführende Informationen bzw. Verweise auf externe Informationen

ergänzt.

Die Prüfaspekte geben das Vorgehen des Prüfers („Evaluator“) vor. Dies ist als Rahmen bzw. Mindestanforderung zu verstehen, da der Prüfer, wie in Kapitel 5 beschrieben, ein ggf. vorhandenes (Rest-) Risiko zu identifizieren und zu bewerten hat, um insgesamt zu einem nachvollziehbaren Prüfungsergebnis zu gelangen.

Die Prüftiefe wird in Kapitel 5.1 beschrieben.

Die weiterführenden Hinweise beinhalten, wenn vorhanden, Verweise auf korrespondierende Vorgaben aus sonstigen technischen und regulatorischen Texten. Diese sollten dem Prüfer bereits bekannt sein und sind bei der Bewertung zu berücksichtigen.

Anhang B kann als Vorlage zur Dokumentation und Protokollierung genutzt werden. Hierzu stehen die letzten zwei Spalten für die Anmerkungen des Prüfers (siehe Kapitel 5.2) sowie das Prüfergebnis (siehe Tabelle 14) zur Verfügung.

Abkürzungsverzeichnis

API	Application Programming Interface (Anwendungs-/Programmierschnittstelle)
App	Applikation
A.*	Assumption (Annahme)
BaFin	Bundesanstalt für Finanzdienstleistungsaufsicht
BSI	Bundesamt für Sicherheit in der Informationstechnik
CCEM	Common Criteria Evaluation Methodology
DORA	Digital Operational Resilience Act
GPS	Global Positioning System
HTML5	Hypertext Markup Language 5
HTTP	Hypertext Transfer Protocol
HTTPS	Hypertext Transfer Protocol Secure
iOS	Betriebssystem des Unternehmens Apple für mobile Geräte
IPC	Interprozess Kommunikation
O.*	Objective (Prüfaspekt)
OSP.*	Organizational Security Policies (Organisatorische Sicherheitspolitiken)
PSD2	Payment Services Directive 2
SDK	Software Development Kit
SSID	Service Set Identifier
T.*	Threat (Bedrohung)
TR	Technische Richtlinie
TLS	Transport Layer Security
URL	Uniform Resource Locator
WiFi	Wireless Fidelity
XML	Extensible Markup Language

Literaturverzeichnis

[BSI200-3]

Bundesamt für Sicherheit in der Informationstechnik, „BSI-Standard 200-3 Risikoanalyse auf der Basis von IT-Grundschutz“, Version 1.0, verfügbar unter <https://www.bsi.bund.de/dok/10027822>

[ISO27005]

BS ISO/IEC 27005:2011, Information technology - Security techniques – Information security risk management

[KCC-C5]

Bundesamt für Sicherheit in der Informationstechnik, „Kriterienkatalog Cloud Computing“, Version 2026, verfügbar unter <https://www.bsi.bund.de/dok/7685384>

[NIST80057]

National Institute of Standards and Technology, „Recommendation for Key Management“, Revision 5, verfügbar unter <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-57pt1r5.pdf>

[PSD2]

<https://www.bundesbank.de/de/aufgaben/unbarer-zahlungsverkehr/psd2/>

[DORA]

<https://www.bundesbank.de/de/service/meldewesen/bankenaufsicht/europaeisches-meldewesen/digital-operational-resilience-act-dora--951046>

[TR02102-1]

Bundesamt für Sicherheit in der Informationstechnik, „Kryptographische Verfahren: Empfehlungen und Schlüssellängen“, Version 2026-01, verfügbar unter <https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/TechnischeRichtlinien/TR02102/BSI-TR-02102.html>

[TR02102-2]

Bundesamt für Sicherheit in der Informationstechnik, „Kryptographische Verfahren: Empfehlungen und Schlüssellängen Teil 2 – Verwendung von Transport Layer Security (TLS)“, Version 2026-01, verfügbar unter <https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/TechnischeRichtlinien/TR02102/BSI-TR-02102-2.html>

[TR03107-1]

Bundesamt für Sicherheit in der Informationstechnik, „Elektronische Identitäten und Vertrauensdienste im E-Government Teil 1“, Version 1.1.1, verfügbar unter <https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/TechnischeRichtlinien/TR03107/TR-03107-1.html>

[TR03174-2]

Bundesamt für Sicherheit in der Informationstechnik, „Sichere Anwendungen im Finanzwesen Teil 2: Web-Anwendungen“, Version 4.0

[TR03174-3]

Bundesamt für Sicherheit in der Informationstechnik, „Sichere Anwendungen im Finanzwesen Teil 3: Hintergrundsysteme“, Version 4.0